

SWE308: Information Security

Lecture 12: Network Security - II

Dr Iftekhar Salam
iftekhar.salam@xmu.edu.my

Xiamen Univesity Malaysia

Presentation outline

- 1 Communication Protocols
- 2 SSL/TLS
- 3 IP Layer Security
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

Communication Protocol Stacks

Client-server communications

- Client requests resource or service,
- Server responds to request
 - Server type depends on resource: web server, file server, ...

Happens at the application layer:

- Clients identify program they want to use (has port number)
- Application servers listen for messages on particular ports
 - web servers: port 80 (HTTP), 443 (HTTPS)
 - email servers: port 25 (SMTP), 110 (POP)
 - login: port 22 (SSH), 23 (Telnet)
 - file transfer: port 20/21 (FTP), 22 (SFTP/SCP)
- Clients identify machine they want to connect to by IP address
 - URLs are translated to IP addresses by the DNS protocol

IETF Internet Protocol Suite: Examples

Layer		Examples
Internet Engineering Task Force (IETF) Protocol Suite	Application	Web (HTTP, HTTPS) email (SMTP, POP3, IMAP) Remote login (SSH, Telnet)
	Transport	connection-oriented (TCP) connectionless (UDP)
	Internet	addressing and routing: • IPv4, IPv6 control (ICMP) security (IPsec)
	Link	packet framing (Ethernet) physical connection • WLAN (WEP, WPA) • ADSL • GSM/3G

Presentation Outline

- 1 Communication Protocols
- 2 SSL/TLS
- 3 IP Layer Security
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

HTTP

Hypertext Transfer Protocol (HTTP)

- Developed in 1990 by Tim Berners-Lee
- Application layer protocol

HTTP is a request/response protocol:

- Clients (web browsers) request access to a resource
 - Resource identified by Uniform Resource Locators (URLs)
- Servers (computers hosting the requested web sites) respond to the request
 - Response could be provision of material requested, or
 - Error message: 4xx status codes used for client request error responses
 - Example: 404 Not found

HTTP Authentication

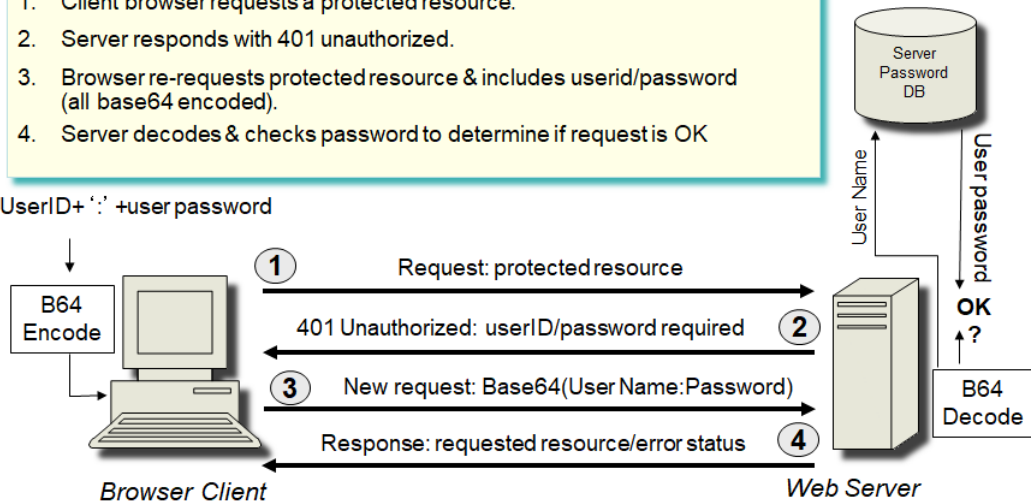
HTTP and access control

- Requests for access to **restricted resources** require provision of **credentials** to enable **user authentication**
- If unauthorised request is made, server response is:
 - 401 Unauthorized: Request requires user authentication.
 - Client MAY repeat the request with a suitable response.
- HTTP Authentication allows the browser to provide username and password when making a request:
 - Two forms defined in RFC 2617
 - **Basic** and
 - **Digest** authentication

HTTP: Basic Authentication

1. Client browser requests a protected resource.
2. Server responds with 401 unauthorized.
3. Browser re-requests protected resource & includes userid/password (all base64 encoded).
4. Server decodes & checks password to determine if request is OK

UserID+ ':' +user password



HTTP: Basic Authentication

Serious information security problem:

- Client response includes user ID and password, base64 encoded
 - Essentially, cleartext transmission of user's password over the physical network
- How can this be exploited?
 - Sniffers or eavesdropper can capture user ID and password
 - 'Fake' web servers can spoof a 'real' server and entice users to send their user IDs and passwords

NOTE: Basic authentication should not be used (alone) to protect sensitive or valuable information transmitted over insecure channels

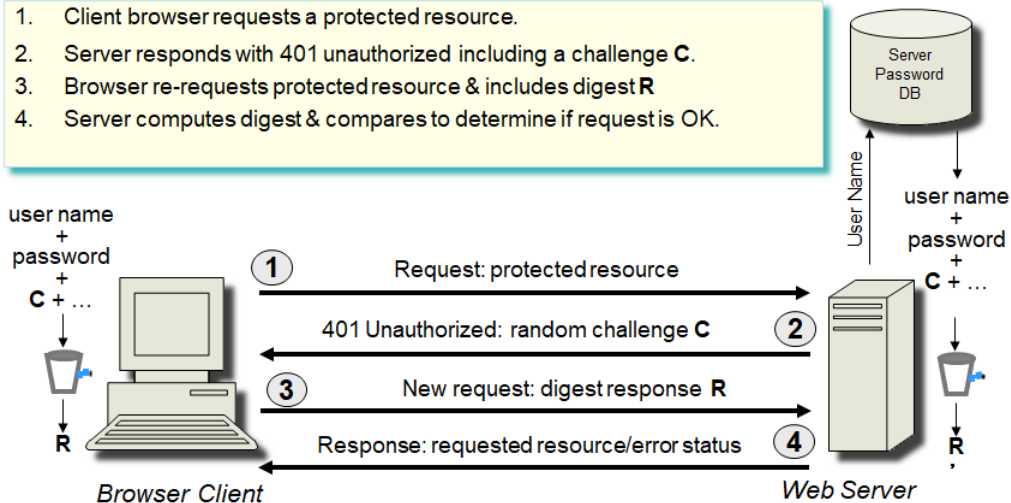
HTTP: Digest Authentication

Digest authentication scheme:

- does not transmit unprotected passwords
- Instead, uses a simple challenge-response paradigm:
 - The challenge is a nonce value
 - (nonce = randomly chosen number and used only once)
 - A valid response contains an MD5 hash of values such as:
 - the username,
 - the password,
 - the given nonce value,
 - the HTTP method, and
 - the requested URI
 - The response is sent as the Request-Digest field.

HTTP: Digest Authentication

1. Client browser requests a protected resource.
2. Server responds with 401 unauthorized including a challenge **C**.
3. Browser re-requests protected resource & includes digest **R**
4. Server computes digest & compares to determine if request is OK.



HTTP: Digest authentication

Digest authentication security:

- More secure than basic authentication as does not transmit unprotected passwords
- However, an eavesdropper may be able to calculate a password using an online dictionary attack:
 - Attacker has a list of common passwords (dictionary)
 - Dictionary usually much smaller than number of possible passwords
 - Attacker captures nonce/response pairs
 - For the given nonce, the response for each password in the dictionary is determined and compared to the captured response value
- The server can mitigate this attack by not allowing users to select weak passwords

HTTP Authentication Security

Man-in-the-middle attacks:

- Both Basic and Digest authentication are vulnerable to man-in-the-middle (MITM) attacks
 - For example, from a hostile or compromised intermediary
- Same problems as eavesdropping, but also offers some additional opportunities
 - For Digest, the MITM could change the challenge to one that requests only Basic authentication
- Some browsers warn users if password is sent in the clear

HTTP Authentication Security

HTTP Authentication Security: Server Side

- Both schemes rely on user/client providing a password and the server 'checking' this password
 - Basic: Server decodes (base 64) to recover password and compares to entry stored in its password database
 - Digest: Server computes a hash value and compares this to the received value.
- Username and password must be prearranged – how this should be done is not addressed by RFC2617
- The password file stored on the server must be secured

(Perfect) Forward secrecy (PFS)

An adversary who later learns the **server's long-term private key** shouldn't be able to read previous transmissions

Presentation Outline

- 1 Communication Protocols
- 2 **SSL/TLS**
- 3 IP Layer Security
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

SSL/TLS

SSL: Secure Sockets Layer

- Proposed by Netscape
 - SSLv2: 1995
 - SSLv3: 1996

TLS: Transport Layer Security

- IETF Standardization of SSL
 - TLSv1.0 = SSLv3: 1999
 - TLSv1.1: 2006
 - TLSv1.2: 2008
 - TLSv1.3: 2018

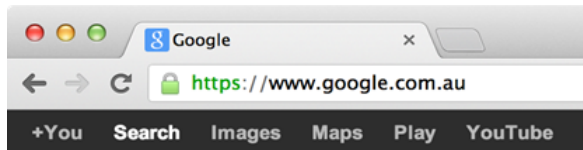
SSL/TLS

Transport Layer Security (TLS)

- a cryptographic protocol that operates just above the **transport layer** - sits on top of Transmission Control Protocol
 - Uses encryption & PKI: X.509 certificates for entity public keys
- Can provide confidentiality and/or authentication for higher level network communication protocols

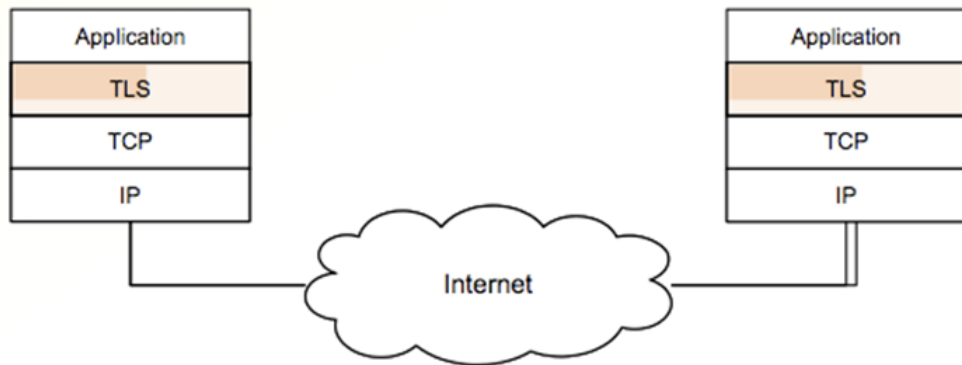
Example:

- HTTP uses port 80,
- HTTPS is HTTP over TLS, uses port 443

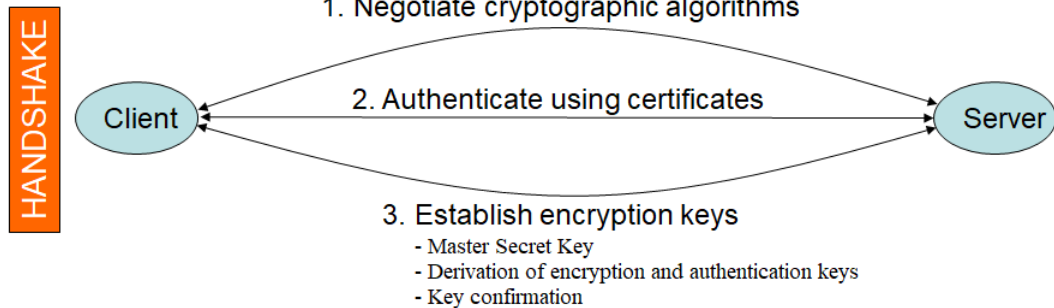


TLS

Encryption and authentication layer added to the protocol stack between TCP and applications



SSL/TLS Protocols



SSL/TLS Protocols

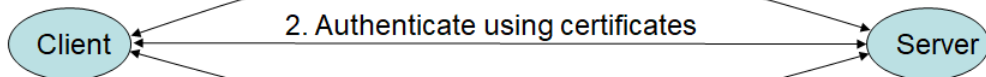
1. Negotiate cryptographic algorithms

2. Authenticate using certificates

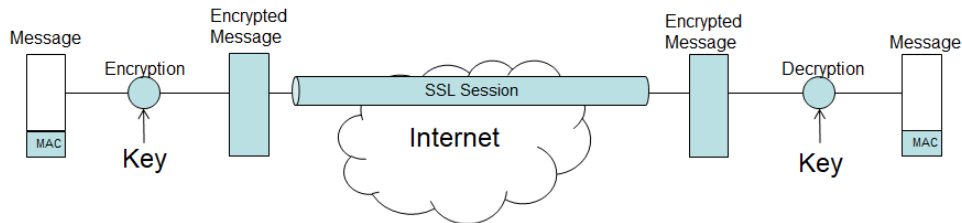
3. Establish encryption keys

- Master Secret Key
- Derivation of encryption and authentication keys
- Key confirmation

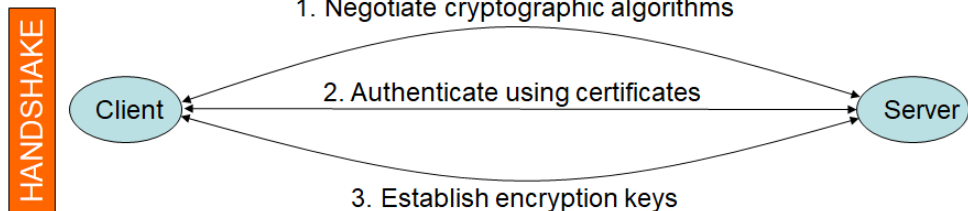
HANDSHAKE



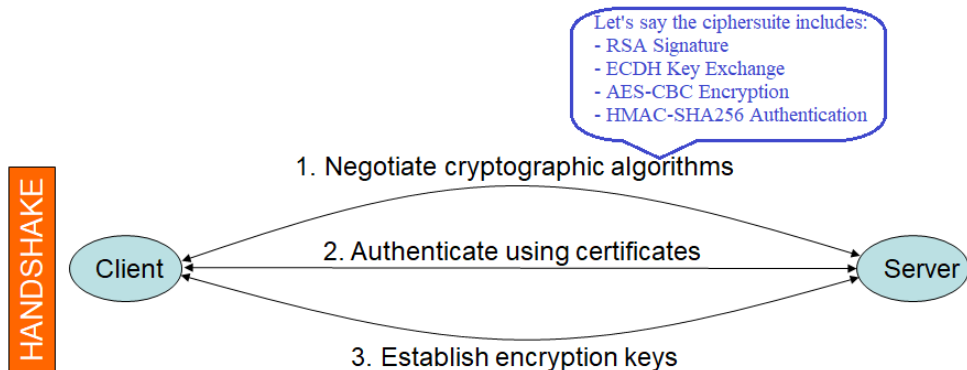
RECORD LAYER



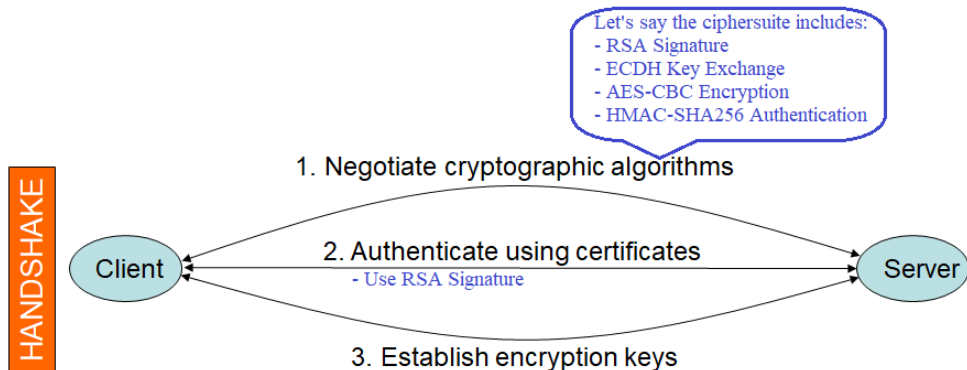
SSL/TLS Protocols



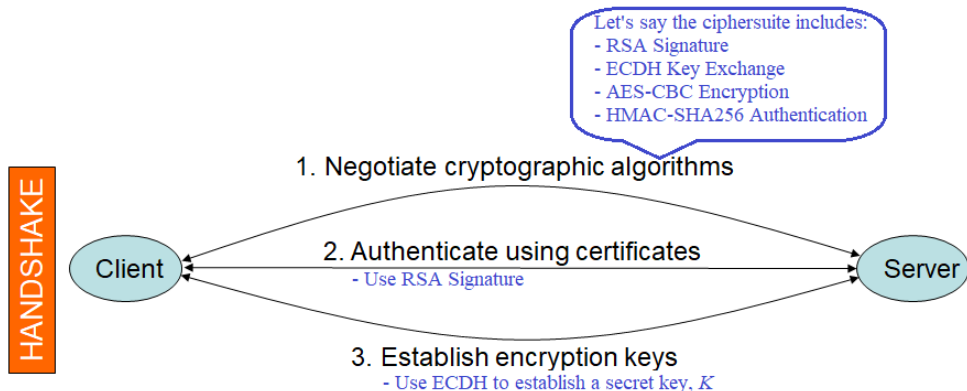
SSL/TLS Protocols



SSL/TLS Protocols



SSL/TLS Protocols

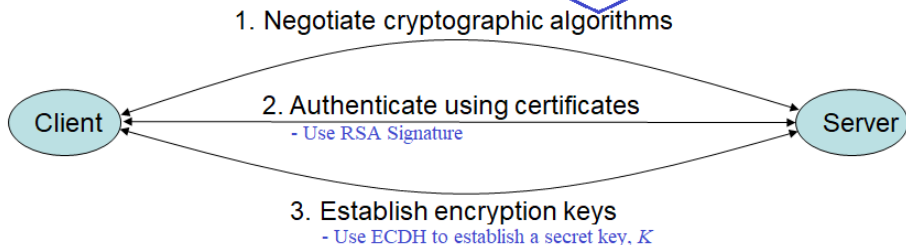


SSL/TLS Protocols

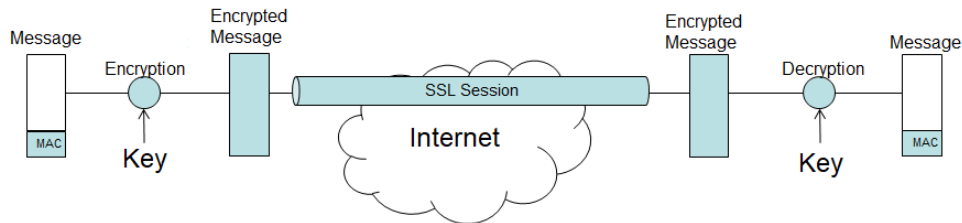
Let's say the ciphersuite includes:

- RSA Signature
- ECDH Key Exchange
- AES-CBC Encryption
- HMAC-SHA256 Authentication

HANDSHAKE



RECORD LAYER



SSL/TLS Protocols

Let's say the ciphersuite includes:

- RSA Signature
- ECDH Key Exchange
- AES-CBC Encryption
- HMAC-SHA256 Authentication

1. Negotiate cryptographic algorithms

2. Authenticate using certificates

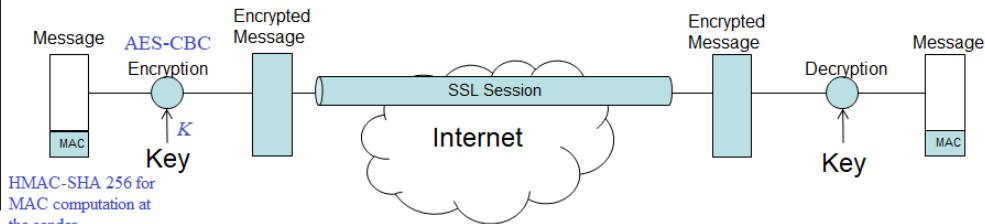
- Use RSA Signature

3. Establish encryption keys

- Use ECDH to establish a secret key, K

HANDSHAKE

RECORD LAYER

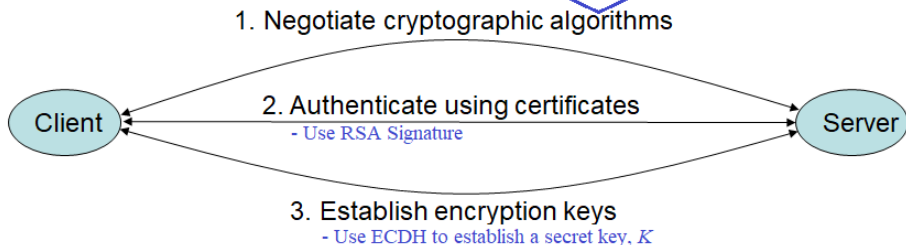


SSL/TLS Protocols

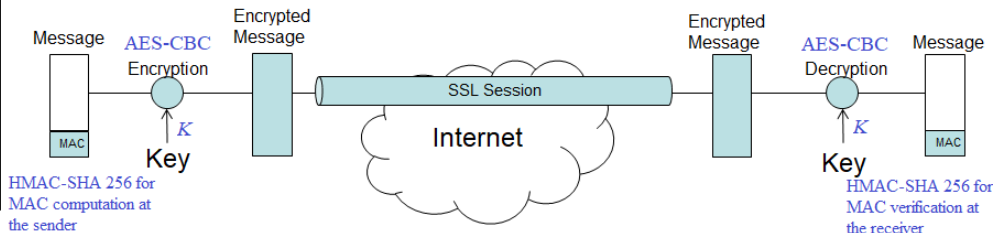
Let's say the ciphersuite includes:

- RSA Signature
- ECDH Key Exchange
- AES-CBC Encryption
- HMAC-SHA256 Authentication

HANDSHAKE



RECORD LAYER



TLS Handshake Example

Client (web browser)

1. Hello! Here are the algorithms I
know how to use: ...



TLS Handshake Example

Client (web browser)

1. Hello! Here are the algorithms I know how to use: ...



Server (web server)

2. Hello! Okay, let's use this "ciphersuite": RSA signatures, ECDH key exchange, AES-CBC encryption, HMAC-SHA256 authentication.



TLS Handshake Example

Client (web browser)

1. Hello! Here are the algorithms I know how to use: ...



Server (web server)

2. Hello! Okay, let's use this "ciphersuite": RSA signatures, ECDH key exchange, AES-CBC encryption, HMAC-SHA256 authentication.



3. Here's my certificate with my RSA public key. Here's a Diffie-Hellman key g^x . And here's a signature on my DH public key to prove it's mine.



TLS Handshake Example

Client (web browser)

1. Hello! Here are the algorithms I know how to use: ...



Server (web server)

2. Hello! Okay, let's use this "ciphersuite": RSA signatures, ECDH key exchange, AES-CBC encryption, HMAC-SHA256 authentication.



3. Here's my certificate with my RSA public key. Here's a Diffie-Hellman key g^x . And here's a signature on my DH public key to prove it's mine.



4. *Check that the certificate is valid. (Signed by a trusted CA, domain name of server matches subject common name in certificate, validity period okay.)*

5. *Check that signature on DH public key is okay.*

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



Server (web server)

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



7. *Compute DH shared secret g^{xy} .*

Server (web server)

7. *Compute DH shared secret g^{xy} .*

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



7. *Compute DH shared secret g^{xy} .*

Server (web server)

7. *Compute DH shared secret g^{xy} .*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret. *This proves no one modified our handshake.*



Server (web server)

7. *Compute DH shared secret g^{xy} .*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .

7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.

This proves no one modified our handshake.

Server (web server)

7. *Compute DH shared secret g^{xy} .*

9. *Check the MAC.*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret. *This proves no one modified our handshake.*



Server (web server)

7. *Compute DH shared secret g^{xy} .*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

9. *Check the MAC.*

10. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .



7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret. *This proves no one modified our handshake.*



11. *Check the MAC.*



Server (web server)

7. *Compute DH shared secret g^{xy} .*

9. *Check the MAC.*

10. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .

7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret. *This proves no one modified our handshake.*

11. *Check the MAC.*

12. *Handshake's done!*

Server (web server)

7. *Compute DH shared secret g^{xy} .*

9. *Check the MAC.*

10. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.

12. *Handshake's done!*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Handshake Example

Client (web browser)

6. Here's my DH public key g^y .

7. *Compute DH shared secret g^{xy} .*

8. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.
This proves no one modified our handshake.

11. *Check the MAC.*

12. *Handshake's done!*

Server (web server)

7. *Compute DH shared secret g^{xy} .*

9. *Check the MAC.*

10. Here's a MAC authentication of all messages we exchanged so far, using the DH shared secret.

12. *Handshake's done!*

Notice shared secret g^{xy} is independent of long-term keys
=> forward secrecy

TLS Record layer

13. Start sending application data, encrypted using AES-CBC and authenticated using HMAC-SHA256, keys derived from DH shared secret.

TLS Handshake - Negotiate Cipher Suite

- ① Determine the algorithm from a set of algorithms (**cipher suite**) that will be used for protecting the communication¹
 - cipher suites usually contains
 - a key exchange algorithm,
 - a bulk encryption algorithm, and
 - a message authentication code (MAC) algorithm
 - An example of a cipher suite name: **TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256**²
 - Protocol: Transport Layer Security (TLS)
 - Key Exchange: Elliptic Curve Diffie-Hellman Ephemeral (ECDHE)
 - Authentication: Rivest Shamir Adleman algorithm (RSA)
 - Encryption: Advanced Encryption Standard with 128bit key in Galois/Counter mode (AES 128 GCM)
 - Hash: Secure Hash Algorithm 256 (SHA256)
 - Can further change the negotiated ciphers by using the **ChangeCipherSpec** protocol in the current handshake or in a new handshake

¹<https://www.iana.org/assignments/tls-parameters/tls-parameters.xhtml#tls-parameters-4>

²https://ciphersuite.info/cs/TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256/

TLS Handshake - Negotiate Cipher Suite

Algorithms supported in TLS 1.0–1.2 cipher suites

Key exchange/agreement	Authentication	Block/stream ciphers	Message authentication
RSA	RSA	RC4	Hash-based MD5
Diffie–Hellman	DSA	Triple DES	SHA hash function
ECDH	ECDSA	AES	
SRP		IDEA	
PSK		DES	
		Camellia	
		ChaCha20	

TLS 1.3

- many legacy algorithms that were supported in early versions of TLS have been dropped in an effort to make the protocol more secure
- all encryption and authentication algorithms are combined in the authenticated encryption with associated data (AEAD) encryption algorithm
- SSL/TLS support over time: <https://www.ssllabs.com/ssl-pulse/>

https://en.wikipedia.org/wiki/Cipher_suite#cite_note-4

TLS: Handshake Protocol

TLS Handshake protocol provides:

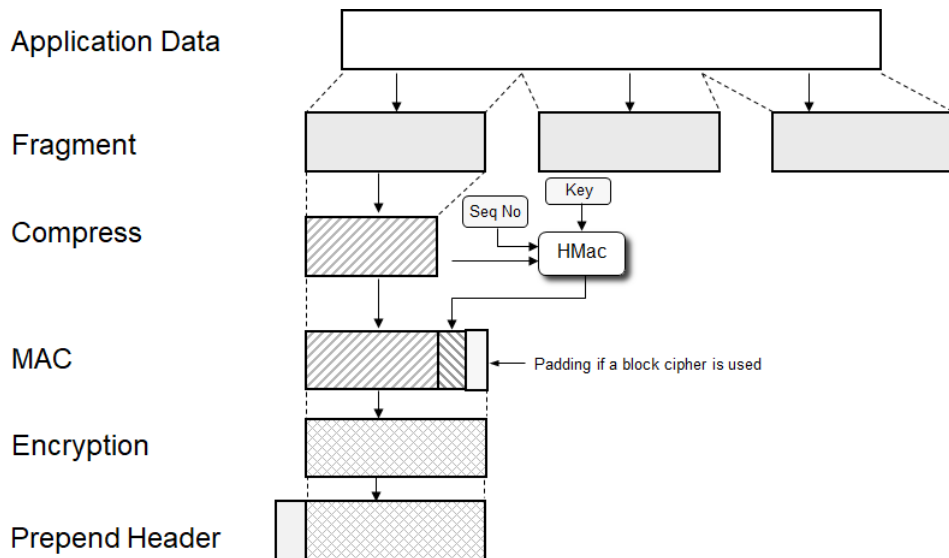
- Authentication (server-to-client):
 - Ensures that the connection really is with the server with the given domain name
- Establishes symmetric key to use in the record protocol for additional security services
 - Confidentiality
 - Integrity assurance

TLS: Record Protocol

TLS Record Protocol provides:

- **Message Confidentiality:**
 - Ensures that message contents cannot be read in transit.
 - Handshake Protocol used first to establish a symmetric key to be used to encrypt SSL/TLS payloads in record protocol
- **Message Integrity:**
 - Ensures that receiver can detect if a message is modified in transmission
 - Handshake Protocol establishes a shared secret key used to construct a Message Authentication Code

TLS: Record Protocol Operation



TLS security considerations

Trust and digital certificates:

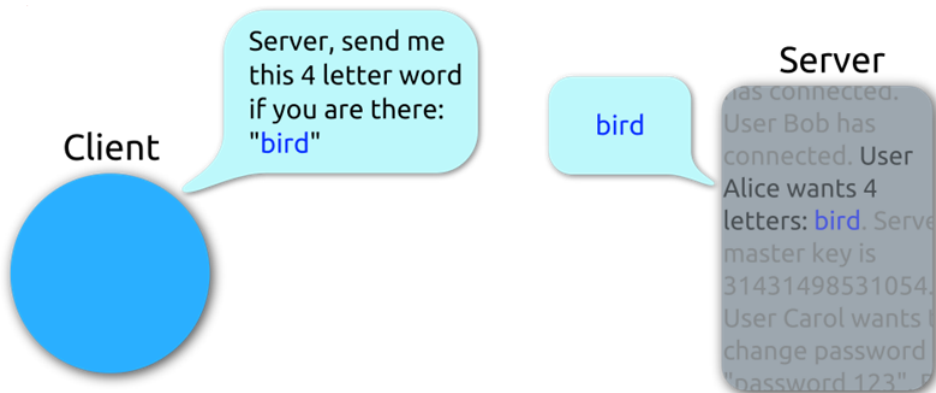
- TLS uses public keys – provided in digital certificates
 - Certificates should be verified – requires tracing certificate pathways
 - Web browsers come with pre-configured lists of root certificates but users can add or remove root CAs
- One-way or mutual authentication?
 - Authentication is usually of server to client only, not mutual
 - Users commonly do not have client certificates
 - Usually authentication of users not performed in handshake
 - Instead, password authentication over server-authenticated HTTPS channel

TLS security incident

The Heartbleed Bug - April 2014

- Problem with the [Heartbeat Extension](#) for the [Transport Layer Security \(TLS\)](#) and [Datagram Transport Layer Security \(DTLS\)](#) protocols
 - Extremely widely used protocols from security vendors implemented in products to secure web browsing
- Implementation in 2012 contained a buffer overflow (vulnerability)
- More data can be read than should be allowed
- Improper input validation
 - Exploitation allowed up to 64Kb of memory to be returned to malicious attacker

Regular SSL Heartbeat Message



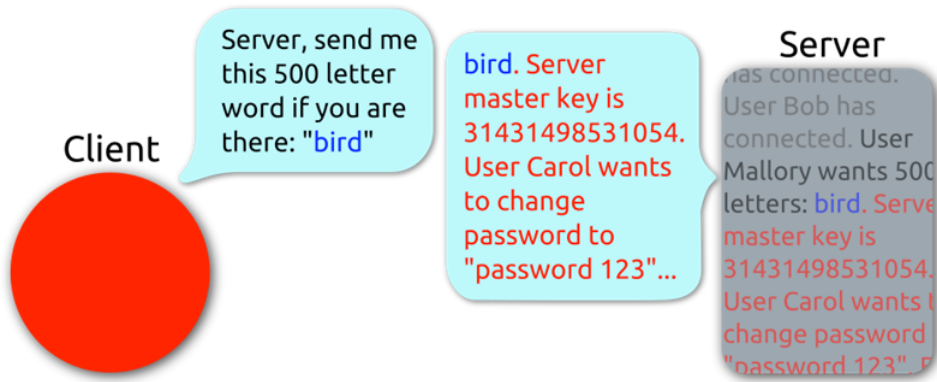
TLS/DTLS secure communication links by allowing a computer at one end of a connection to send a Heartbeat Request message

- Consisting of a payload, along with the payload's length
- Receiving computer then must send exactly the same payload back to the sender
- The receiving party returns the same message based on the length field

Source: <https://en.wikipedia.org/wiki/Heartbleed>

Source: http://en.wikipedia.org/wiki/File:Simplified_Heartbleed_explanation.svg

Malicious Heartbleed Message



TLS/DTLS secure communication links by allowing a computer at one end of a connection to send a Heartbeat Request message

- Affected versions of OpenSSL return message based on the length field in the requesting message, **without regard to the actual size** of that message's payload
- Exploited by sending a malformed heartbeat request with a **small payload and large length field** to the vulnerable party

Source: <https://en.wikipedia.org/wiki/Heartbleed>

Source: http://en.wikipedia.org/wiki/File:Simplified_Heartbleed_explanation.svg

Presentation Outline

- 1 Communication Protocols
- 2 SSL/TLS
- 3 IP Layer Security**
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

Internet Protocol Security

Internet Protocol Security (IPsec)

- Framework of open standards for ensuring private, secure communications over Internet Protocol (IP) networks
- Operates at the Network or Internet layer
 - Can secure application and transport layer communications
- Uses encryption, authentication and key management algorithms to provide end-to-end security
- Specified in RFCs by Internet Engineering Task Force (IETF) Working Group
 - <http://www.ietf.org/html.charters/ipsec-charter.html>
- Provides security architecture for both IPv4 and IPv6

IETF Internet Protocol suite: IPsec

IPsec is transparently applied to all higher level protocols

Layer	Examples
Application	web (HTTP, HTTPS) email (SMTP, POP3, IMAP) login (SSH, Telnet)
Transport	connection-oriented (TCP) connectionless (UDP)
Internet	addressing and routing: • IPv4, IPv6 control (ICMP) security (IPsec)
Link	packet framing (Ethernet) physical connection • WLAN (WEP, WPA) • ADSL • GSM/3G

IPsec is used for all IP traffic between two IP addresses

IPsec: Security Services

Message Confidentiality

- Protects against unauthorised data disclosure
- Accomplished by the use of encryption mechanisms

Traffic Analysis Protection

- A person monitoring network traffic cannot know which parties are communicating, how often, or how much data is being sent
- Provided by concealing IP datagram details such as source and destination address

Message Integrity

- IPsec can determine if data has been changed (intentionally or unintentionally) during transit
- Integrity of data can be assured by using a message authentication code (MAC)

Message Replay Protection

- The same data is not delivered multiple times

Peer Authentication

- Each IPsec endpoint confirms the identity of the other IPsec endpoint it wants to communicate with
- Ensures that network traffic is being sent from the expected host
- IP addresses are used as host identifiers

IPsec: Protocol Types

Encapsulating Security Payload (ESP)

- Confidentiality
- Optionally provides authentication

Authentication Header (AH)

- Authentication, integrity and replay protection. However there is no confidentiality

Internet Key Exchange (IKE)

- negotiate, create, and manage security associations

IPSec: AH

Authentication Header (AH)

- AH is used to authenticate – but not encrypt – IP traffic
- Authentication is performed by computing a cryptographic hash-based message authentication code over nearly all the fields of the IP packet
- stores this in a newly-added AH header that is sent to the other end

Security goals:

- Data integrity
- Data origin authentication
- Optional replay protection

https://www.cisco.com/c/en/us/td/docs/wireless/asr_5000/20/IPSec/b_20_IPSec/b_20_IPSec_chapter_01.html

IPSec: ESP

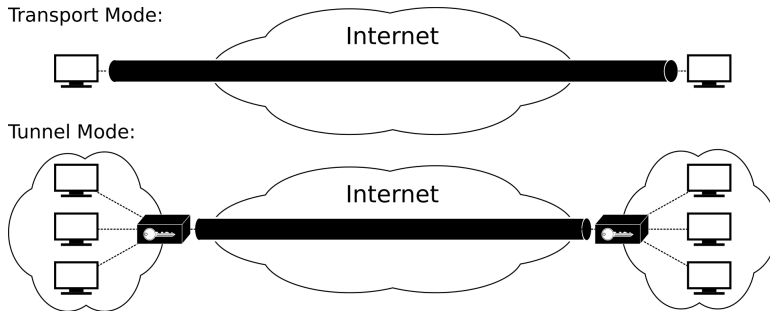
Encapsulating Security Payload

- ESP provides encryption and optional authentication
- It includes header and trailer fields to support the encryption and optional authentication
- Encryption for the IP payload is supported in transport mode and for the entire packet in the tunnel mode
- ESP can be used with confidentiality only, authentication only, or both confidentiality and authentication

Security goals:

- ESP protocol provides data confidentiality (encryption)
- authentication (data integrity, data origin authentication, and replay protection)

IPsec: Modes of operation



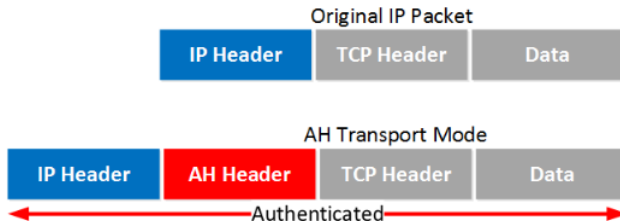
Both ESP and AH protocols can operate in transport or tunnel mode:

- **Transport mode:**
 - Operates primarily on the payload (data) of the original packet
 - Generally only used in host-to-host architectures.
- **Tunnel mode:**
 - Original packet encapsulated into a new one, payload is original packet
 - Typical use is gateway-to-gateway architecture

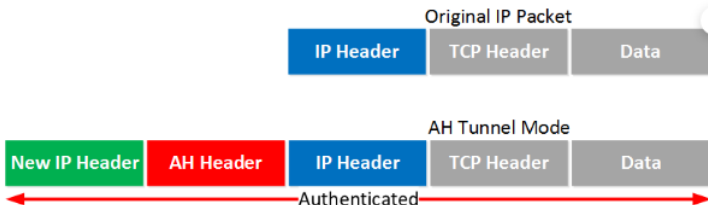
Source: <https://en.wikipedia.org/wiki/IPsec#/media/File:Ipsec-modes.svg>

Authentication Header Protocol

Transport Mode: Transport mode is simple, it just adds an AH header after the IP header.

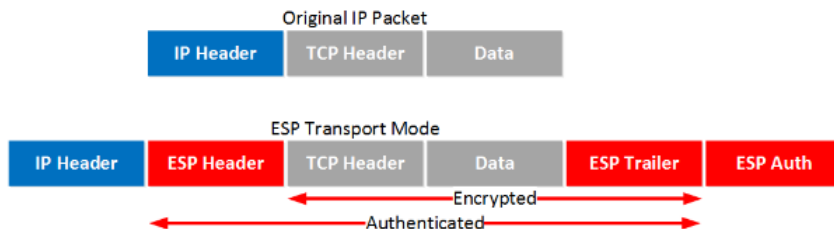


Tunnel Mode: With tunnel mode we add a new IP header on top of the original IP packet.

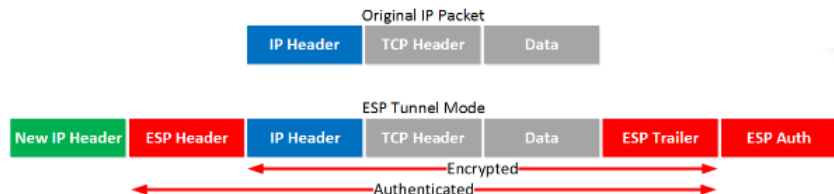


Encapsulating Security Payload Protocol

Transport Mode: we use the original IP header and insert an ESP header.

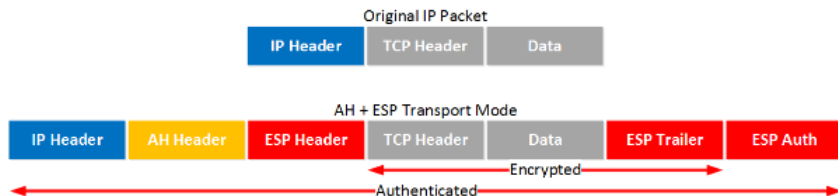


Tunnel Mode: we use a new IP header which is useful for site-to-site VPNs

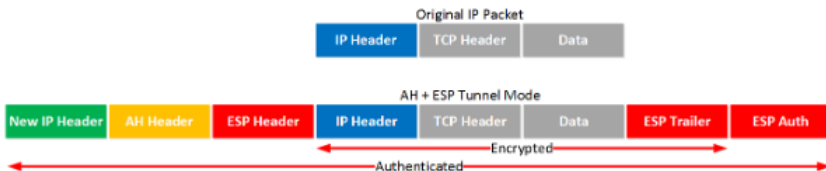


AH and ESP

Transport Mode: we will use the original IP header, followed by an AH and ESP header. The transport layer, payload and ESP trailer will be encrypted. Because we also use AH, the entire IP packet is authenticated.



Tunnel Mode: we will add a new IP header followed by the AH and ESP header. The original IP packet will be completely encrypted and everything will be authenticated.



IPSec: Common Architectures

The endpoints for communications secured using IPSec can be:

- hosts or
- gateways to secured networks

Combinations form 3 common architectures:

- Gateway-to-gateway
- Host-to-gateway
- Host-to-host

IPSec: Gateway-to-Gateway Architecture

Secures network communications between two secure networks

- Network traffic is routed through the IPSec connection
- A Virtual Private Network (VPN) connection is established between the two gateways
- NOTE: Only protects data transmission between the two gateways



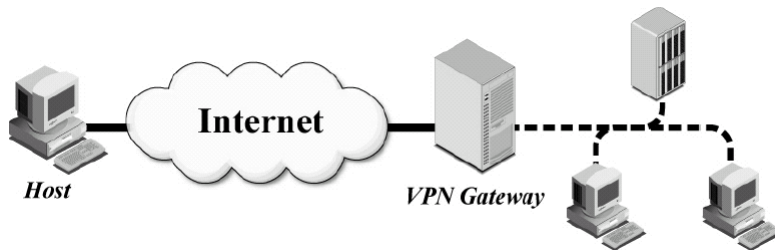
A cheaper alternative to a private wide area network (WAN)

- Example: linking a branch office to headquarters over the Internet

IPSec: Host-to-Gateway Architecture

Secures communications over an insecure connection between a single host and a secure network

- A VPN connection is established between the host and the gateway to the secure network
- NOTE: Only protects the data between the host and the gateway
 - within the secure network the transmissions are not protected



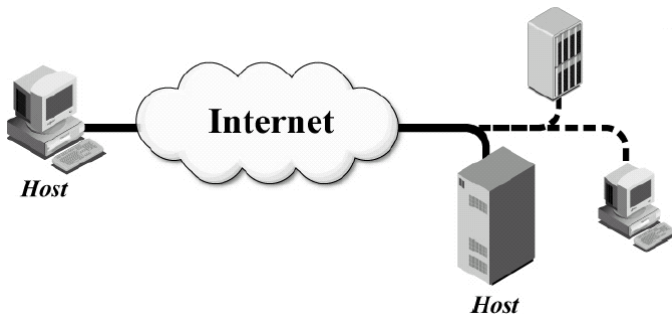
Example: providing access over the Internet for employee working from home to resources located within the company headquarters

- The employee's local computer is the host

IPSec: Host-to-Host Architecture

Secures communications between two single computers

- The only architecture that provides protection for data throughout its transit
- All user systems and servers need to have VPN software installed and/or configured
 - Key establishment is often a manual process
 - Resource-intensive to implement and maintain in terms of user and host management



Example: Could be used for special purpose, such as system administrators performing remote management of a single server

IPSec: Benefits

Transparent to applications

- Operates at Network/Internet layer so applications are not aware of its operation

If applied at a network gateway (firewall/router), strong security applies to all traffic crossing this boundary

- Internal workstations need not be reconfigured
- Can be transparent to end users
 - System administrator configures IPSec; the end user is not involved

Summary

Networks:

- computers and other devices, connected by communications channels
- Must secure both the devices and communication channels

Communications protocols:

- **HTTP Authentication:**
 - Basic authentication: used alone is not secure
 - Digest authentication: better, but still weaker than public-key based
- **TLS:**
 - Handshake protocol: authentication (who?), establish symmetric key Record protocol: symmetric encryption and MAC
- **IPSec:**
 - Two modes: transport and tunnel
 - Define various architectures: H-to-H, H-to- G, G-to-G.

End of Lecture 12! 😊

Done with the lecture contents (syllabus completed!). Yay!

Well, nearly there! Just hang in there for couple of more weeks!

- Still have couple of more quizzes to complete!

Next week (W14) lecture session

- Solving selected past year problems (students to solve the problems in the class!)

We also have revisions on W14. Email me if you want me to discuss any particular topic during the revision



Acknowledgments

- The slides are adapted from materials prepared by Leonie Simpson and Douglas Stebila for the Information Security course taught at QUT, Australia.

QUESTIONS?

Presentation Outline

- 1 Communication Protocols
- 2 SSL/TLS
- 3 IP Layer Security
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

No Anonymity on the Internet



131.181.46.152

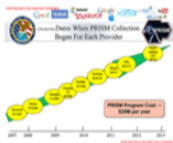


theguardian
The New York Times

No Anonymity on the Internet



131.181.46.152



theguardian
The New York Times

No Anonymity on the Internet



131.181.46.152



theguardian
The New York Times

No Anonymity on the Internet



131.181.46.152



the guardian
The New York Times



This came from
131.181.46.152

No Anonymity on the Internet



131.181.46.152



the guardian
The New York Times



This came from
131.181.46.152

No Anonymity on the Internet

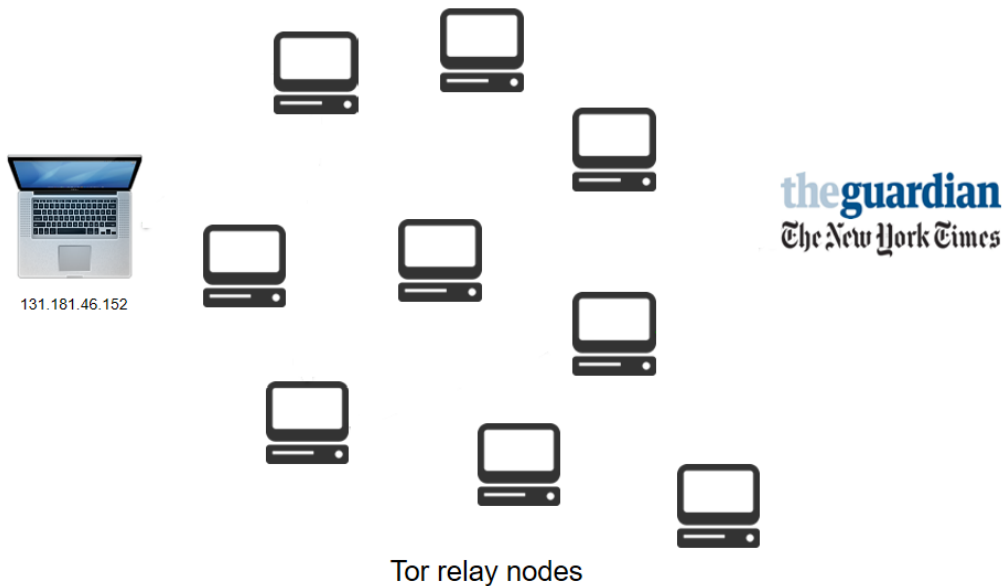


Tor – Anonymity Network

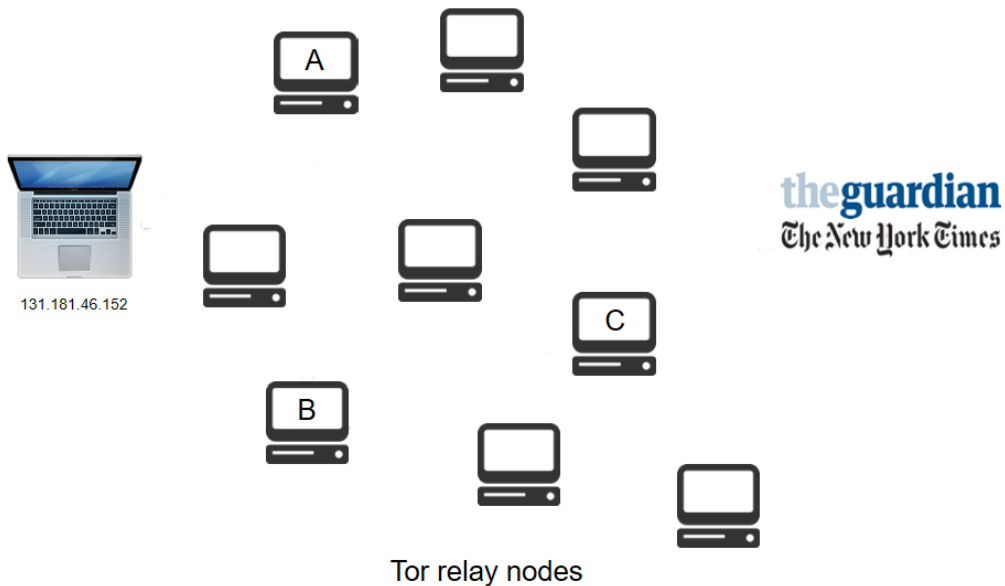
Tor browser (<https://www.torproject.org/>)

- Basic operation: use the Tor browser to browse normal websites “anonymously”
 - Modified Firefox that tries to reduce amount of information that leaks
- hides metadata and content
- obscures traffic patterns
- used by:
 - journalists
 - whistleblowers
 - dissidents
 - activists
 - law enforcement
 - privacy-conscious citizens
 - ... criminals

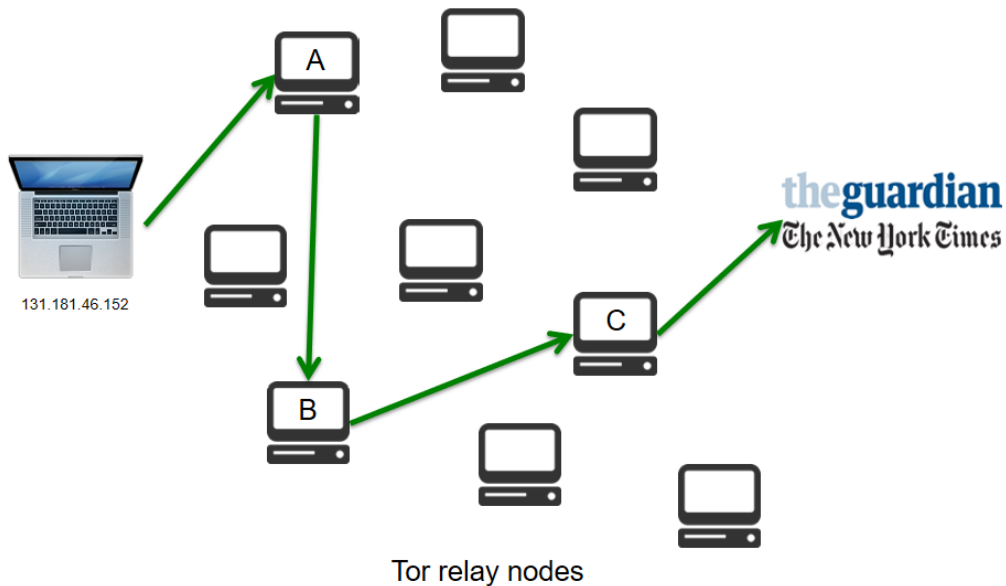
Tor Anonymity Network



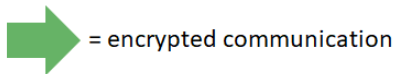
Tor Anonymity Network



Tor Anonymity Network



Tor – Anonymity Network

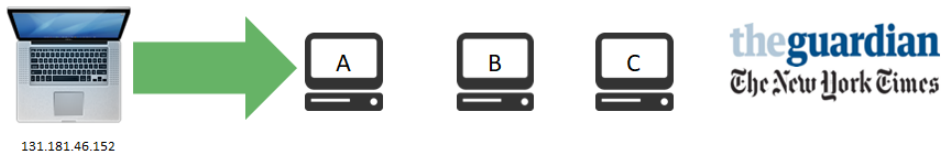


131.181.46.152

theguardian
The New York Times

Tor – Anonymity Network

 = encrypted communication



Tor – Anonymity Network

 = encrypted communication



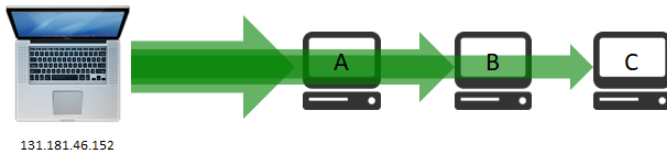
131.181.46.152



theguardian
The New York Times

Tor – Anonymity Network

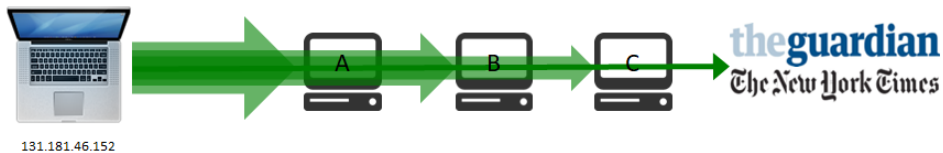
 = encrypted communication



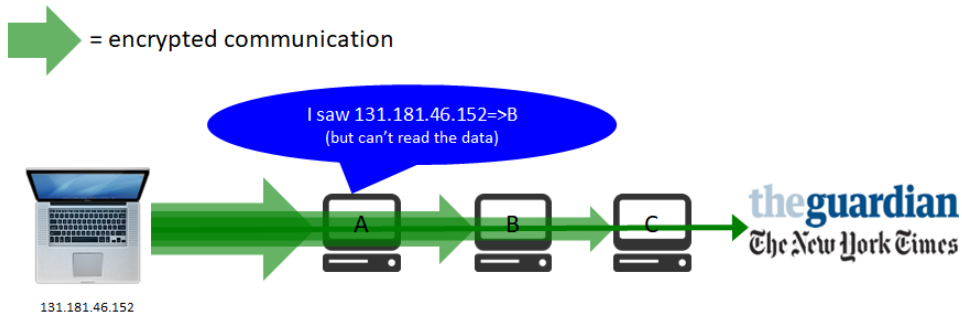
theguardian
The New York Times

Tor – Anonymity Network

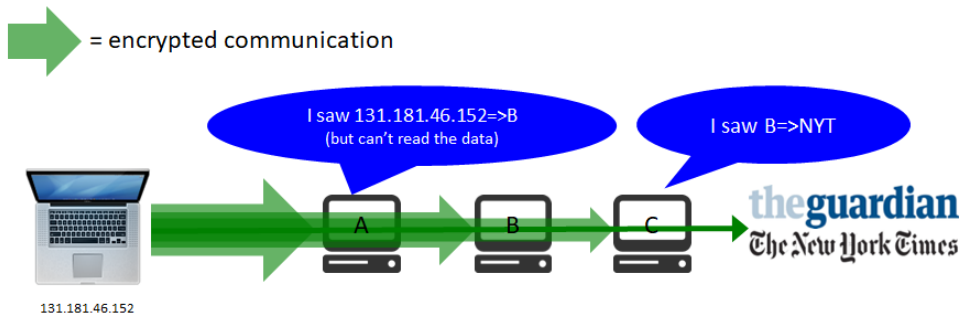
 = encrypted communication



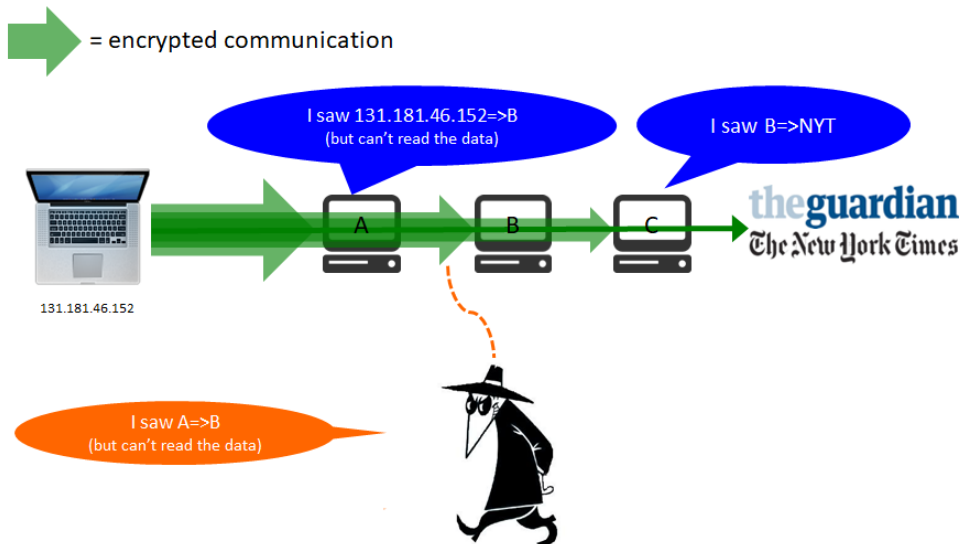
Tor – Anonymity Network



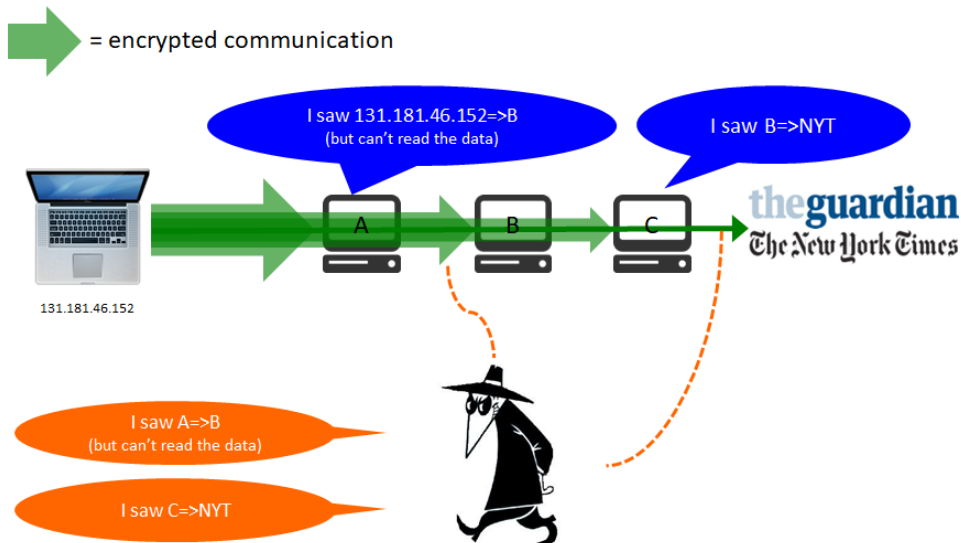
Tor – Anonymity Network



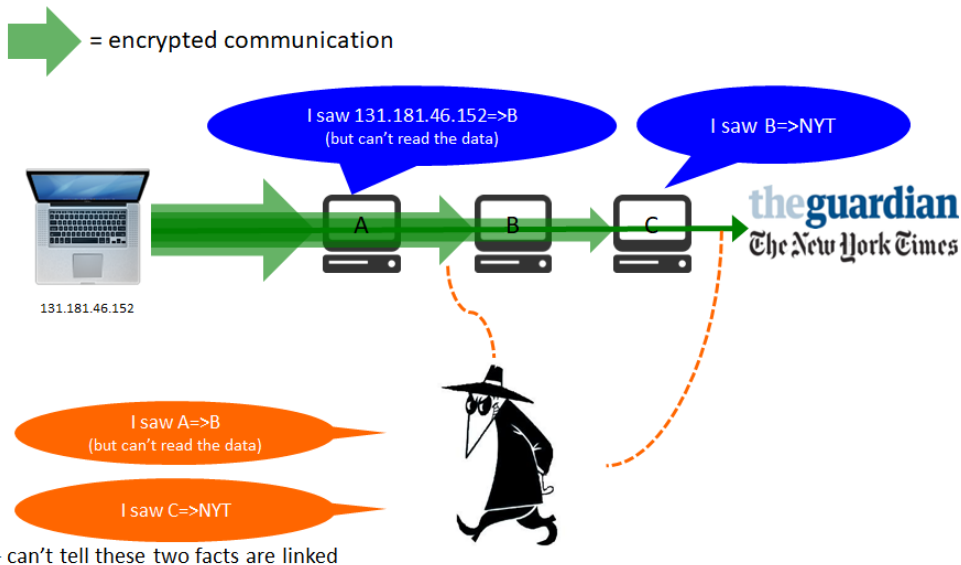
Tor – Anonymity Network



Tor – Anonymity Network

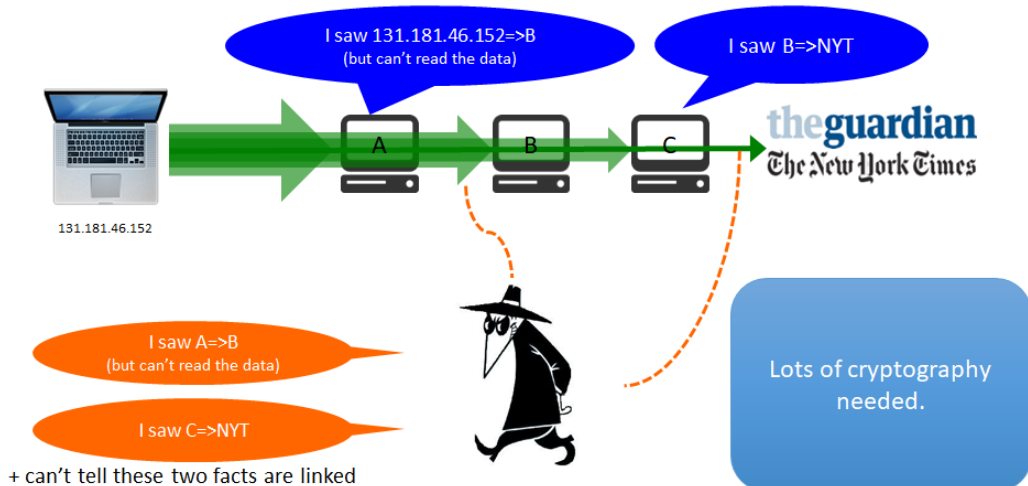


Tor – Anonymity Network

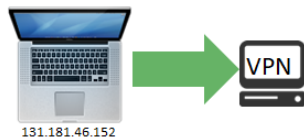


Tor – Anonymity Network

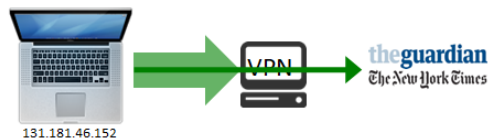
 = encrypted communication



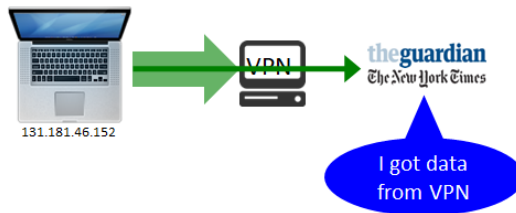
VPNs vs Tor



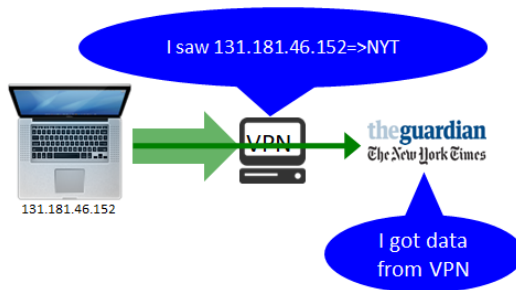
VPNs vs Tor



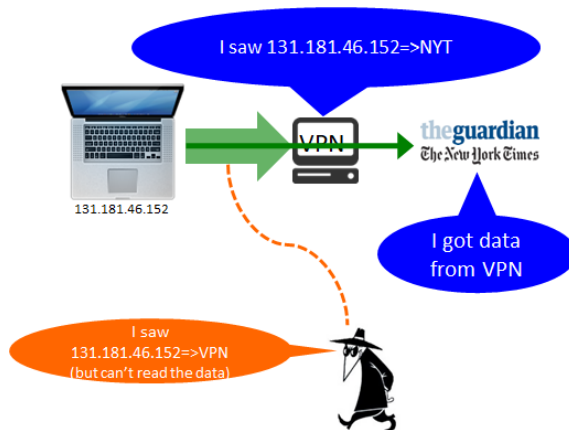
VPNs vs Tor



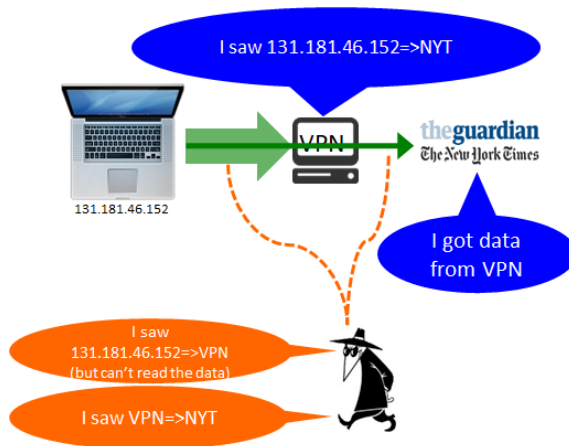
VPNs vs Tor



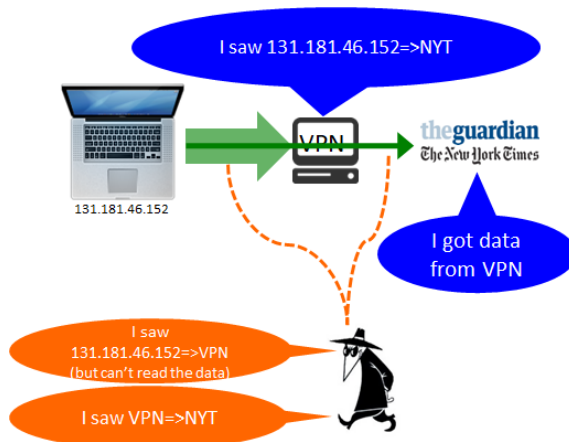
VPNs vs Tor



VPNs vs Tor



VPNs vs Tor



maybe can tell these two facts are linked?

VPNs vs Tor

- Using a VPN routes traffic through 1 hop
- Using Tor routes traffic through 3 hops
- VPNs versus Tor:
 - Higher performance
 - Less privacy
 - VPN provider knows source and destination...does your VPN provider log this?
 - Easier than Tor for global monitors to link behaviour

Presentation Outline

- 1 Communication Protocols
- 2 SSL/TLS
- 3 IP Layer Security
- 4 Appendix: Metadata Privacy and Using Tor
- 5 Appendix: Basic Network Concepts

What is Network?

Network:

- A number of computers and devices, connected by communications channels, and hardware and software to enable data exchange
- The devices can be:
 - Computers, printers, scanners, servers, ...
- The connections can be:
 - Physical: cable, fibre optic, ...
 - Wireless: Radio signal, Infrared, Satellite , ...
- Simple network examples: ?

Data Transmission

Data transmission over network:

- Electronic data is binary digits (bits): 0 and 1
- Grouped into bytes: 8 bits
- For transmission, sent as packets:
 - Packet header:
 - Has control information: source and destination network addresses, sequencing information
 - Packet body:
 - Payload - binary data to be transmitted

Protocols

Network Communication Protocols

- Are agreed methods for communications
 - Set of rules defining format for messages exchanged between entities
 - Specify data representation, authentication, error detection etc.
- Important because it permits the communications to be separated from the communication media
 - Same format for communication, regardless of the transmission media: coax cable, optical fibre, wireless, etc

Have different protocols for different types of communications, and operate on different ports

- Example: Hypertext Transfer Protocol (HTTP) on port 80

Protocol Stacks

Communication Protocol Stacks

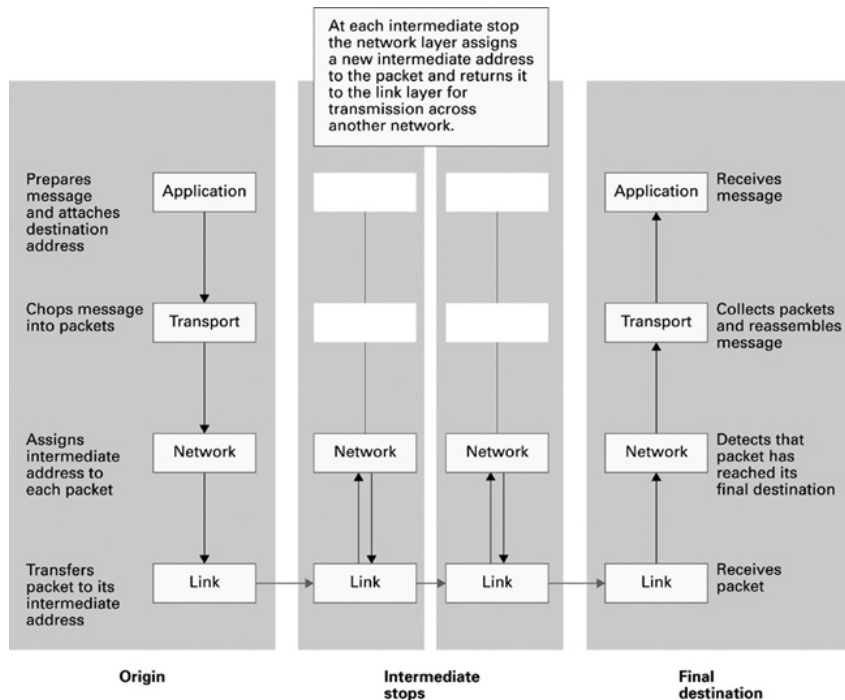
- Network communications use multiple protocols
- Think of these protocols arranged in a layered structure
 - Each layer performs different types of activities required to enable communications between devices
- Two well known models:
 - ISO Open Systems Interconnection (OSI) model
 - 7 layer model
 - IETF Internet Protocol Suite
 - 4 layer model
 - Commonly known as TCP/IP - includes two well known protocols: Transmission Control Protocol and Internet Protocol

Communication Protocol Stacks

IETF Internet Protocol Suite - 4 layers

- Application:
 - Prepares user messages
 - Each application protocol has unique message format
- Transport:
 - Converts messages to packets
 - Uses ports for different applications on same host
- Network/ Internet:
 - Converts packets to datagrams
 - Hosts have unique IP addresses (IPv4: 32 bit, IPv6: 128 bit)
- Link (Network Access) layer:
 - Physical layer, associated with computer hardware
 - Transmission of communication as bits

IETF Internet Protocol Suite



Appendix: University's vision and mission

- ① Vision: Xiamen University Malaysia aspires to become a university with a distinct global outlook, featuring first-class teaching and research, and embracing cultural diversity.
- ② Mission: To nurture young talents with dignity and wisdom, turning them into fine citizens of the region who will contribute to the prosperity of the people and social progress of Malaysia, China and Southeast Asia.